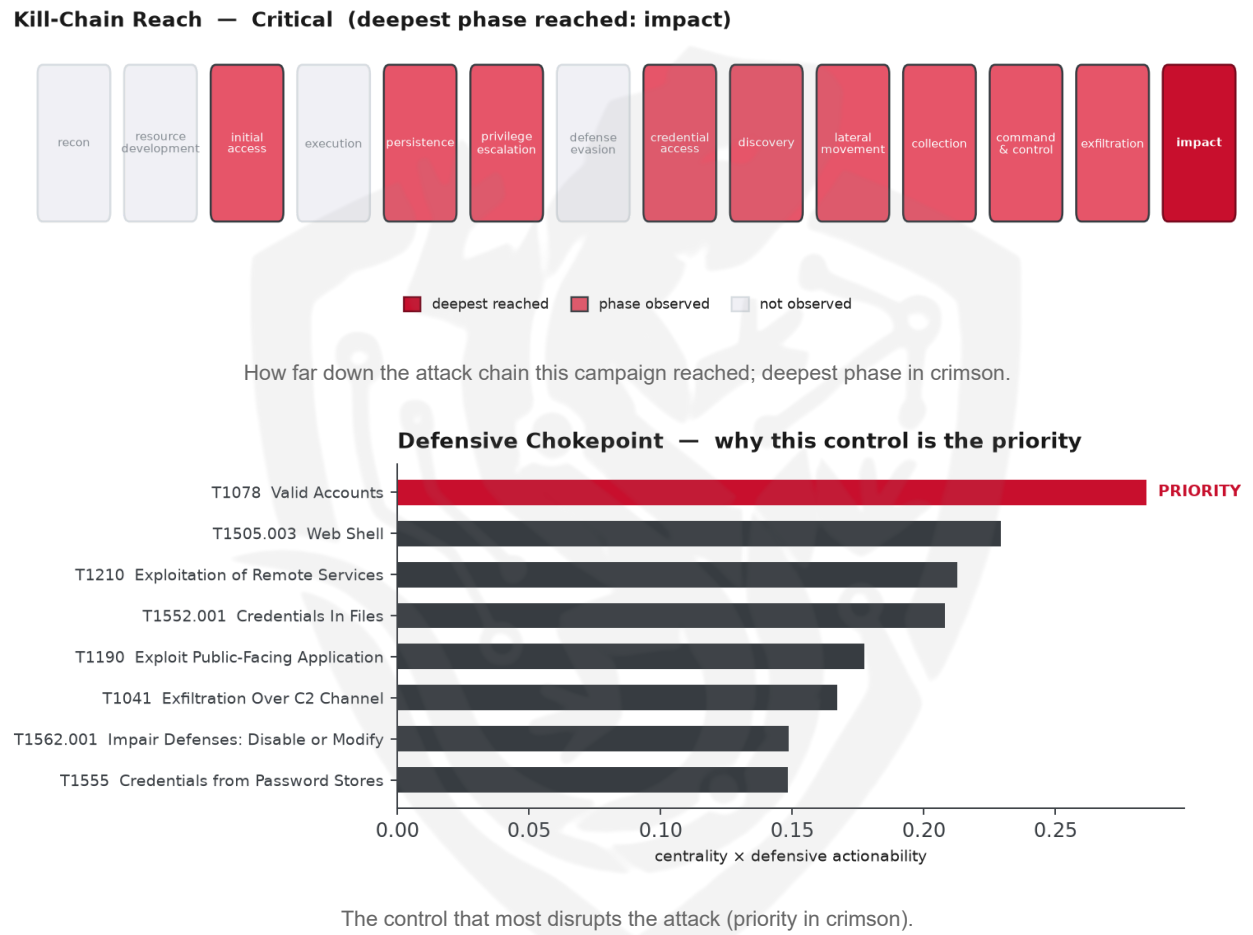


THREAT REPORT: CLOP DEPLOYS CUSTOM IMPLANT IN MASS-EXTORTION CAMPAIGN

Visual Summary



Summary

The threat actor Clop is leveraging a custom implant built on the DEWMODE and LEMURLOOT families to exploit CVE-2023-34362 in a mass-extortion operation targeting the manufacturing sector. The campaign employs a broad set of ATT&CK techniques, including credential dumping, web-shell deployment, and automated exfiltration. Defensive priority should focus on enforcing multi-factor authentication, removing dormant or over-privileged accounts, and promptly patching CVE-2023-34362 across all vulnerable systems.

Threat Overview

Clop utilizes the DEWMODE and LEMURLOOT malware families to exploit the public-facing vulnerability CVE-2023-34362. The group’s activity is directed at organizations within the manufacturing sector, though

specific geographic targeting is not disclosed.

Attack Chain and Priority Control

The observed attack chain begins with exploitation of a public-facing application (T1190) using CVE-2023-34362, followed by deployment of a web shell (T1505.003) and credential acquisition through valid accounts (T1078). Subsequent steps include credential dumping (T1003), data collection from local systems (T1005) and repositories (T1213), obfuscation of files (T1027/T1140), automated exfiltration (T1020) over encrypted channels (T1573/T1041), and finally data encryption for impact (T1486).

Priority technique: T1078 Valid Accounts

Priority control: Enforce MFA on all accounts; disable dormant and over-privileged accounts; alert on impossible-travel and anomalous logons. In parallel, patch CVE-2023-34362 on all affected systems.

Infrastructure and Corroboration

Third-party enrichment shows that the command-and-control infrastructure is hosted by providers MITI 2000 EOOD, GTHost, and GWY IT Pty Ltd, as reported by the source pulse. AbuseIPDB flags no indicators with high confidence (the highest observed confidence is 22 %). No additional malware families have been corroborated by abuse.ch.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1003 OS Credential Dumping
- T1005 Data from Local System
- T1140 Deobfuscate/Decode Files or Information
- T1190 Exploit Public-Facing Application
- T1555 Credentials from Password Stores
- T1505.003 Web Shell
- T1020 Automated Exfiltration
- T1083 File and Directory Discovery
- T1552.001 Credentials In Files
- T1041 Exfiltration Over C2 Channel
- T1210 Exploitation of Remote Services
- T1562.001 Impair Defenses: Disable or Modify Tools
- T1078 Valid Accounts
- T1027 Obfuscated Files or Information
- T1486 Data Encrypted for Impact
- T1573 Encrypted Channel
- T1132 Data Encoding

- T1213 Data from Information Repositories
- T1485 Data Destruction
- T1071.001 Web Protocols

Analytical Scores

- Priority technique (graph chokepoint): T1078 Valid Accounts (centrality 0.2846).
- Operational risk: Critical (score 1.0, reaches impact).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.3772; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Fox Kitten	0.3772
Sandworm Team	0.3472
APT39	0.3266
Ke3chang	0.3223
HAFNIUM	0.3149

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 22%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
IP	78[.]128[.]113[.]10	AbuseIPDB 22% (BG) · AS209160 MITI 20 00 EOOD
IP	216[.]152[.]151[.]204	AbuseIPDB 0% (US) · AS63023 GTHost
IP	185[.]227[.]83[.]236	AbuseIPDB 0% (US) · AS199959 GWY IT Pty Ltd

Type	Indicator	Context
Has h	321e1fb01eb3462b48ff6ccdef132acc1182e3f7456548439f0 d4ead12fd98bf	
Has h	71a7b6b8fa5e21765aeb60d897009aa3	
Has h	2989c71984b9a464c741e5d93171ca9c153baf5d	

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1078 Valid Accounts (initial-access)
- **Observed here:** T1078 Valid Accounts was the initial-access control point; blocking a means-of-entry rarely stops a determined actor, so the pivot projects forward to the execution stage they must still reach.
- **Projected pivot:** T1047 Windows Management Instrumentation (execution)
- **Basis:** of the 29+ groups that use Valid Accounts, this pairing runs 1.8x above base rate, a disproportionately-coupled move rather than the obvious one.

With T1078 Valid Accounts blocked, Clop could preserve the same objective by pivoting to T1047 Windows Management Instrumentation, a technique disproportionately paired with it across tracked groups. Defensive countermeasure: Monitor wmicprvse.exe child-process creation; restrict remote WMI (DCOM) at the host firewall; enable WMI-Activity operational logging.

Also plausible (same tactic): T1569 System Services (n=13, lift 2.0), T1053 Scheduled Task/Job (n=31, lift 1.4)

Detection and hardening for the pivot (T1047 Windows Management Instrumentation)

- **Telemetry:** Sysmon (WMI events); Microsoft-Windows-WMI-Activity/Operational
- **Detect:**
 - Sysmon 19/20/21 (WMI event filter/consumer/binding) for persistence
 - wmic.exe / WmiPrvSE.exe spawning shells; remote WMI process creation
 - WMI-Activity/Operational operations from unusual users/hosts
- **Harden:**
 - Restrict WMI remote access; monitor permanent WMI subscriptions
 - Least-privilege; segment management protocols
- **MITRE:** M1040 Behavior Prevention, M1038 Execution Prevention, M1026 Privileged Account Management · DS0009 Process, DS0005 WMI, DS0017 Command